

Небезопасная конфигурация

Описание проблемы

Небезопасная конфигурация – это состояние, при котором система, приложение или сеть настроены таким образом, что позволяют злоумышленникам получить несанкционированный доступ, выполнить нежелательные действия или нарушить нормальную работу системы. Это может быть следствием неправильной настройки параметров безопасности, использования учетных записей по умолчанию, ненадлежащего управления правами доступа и других факторов.



По данным Open Web Application Security Project (OWASP), в 90% проверенных ими приложений были обнаружены те или иные ошибки конфигурации.

Примеры небезопасной конфигурации:

- Включены или установлены ненужные функции (например, ненужные порты, службы)
- Учетные записи по умолчанию включены и их пароли не изменяются
- Обработка ошибок показывает пользователям трассировки стека или другие слишком информативные сообщения об ошибках. Например:
 - Ошибка сервера, содержащая в себе SQL запрос.
 - Ошибка сервера, содержащая код приложения с указанием места возникшей ошибки.
- Сервер не отправляет заголовки или директивы безопасности, или для них не установлены безопасные значения. Например:
 - Некорректно выставленные атрибуты Cookie (SameSite=None), что может привести к облегчению доступа к Cookie для злоумышленника.
 - Сервер отражает заголовок Origin в своем ответе в заголовке Access-Control-Allow-Origin, что позволяет злоумышленнику использовать в качестве Origin: null и выполнять различные атаки.
- Неправильные/излишние разрешения на файлы, каталоги, методы
- Использование устаревшего или уязвимого программного обеспечения
- Использование устаревших протоколов и алгоритмов
 - При использовании HTTP вместо HTTPS, данные, передаваемые между пользователем и веб-сайтом, не шифруются и могут быть перехвачены злоумышленниками.
 - Использование Telnet и FTP, вместо SSH и SFTP.
 - Использование MD5 или SHA1, вместо более криптостойких хеш-функций.

Последствия эксплуатации

Так как сам перечень мест, где можно допустить ошибку конфигурации очень большой, последствия эксплуатации таких ошибок могут быть очень разными:

- Неавторизованный доступ
- Выполнение произвольного кода
- Нарушение целостности и конфиденциальности данных
- Нарушение работы сервисов и служб

Почему возникают ошибки конфигурации?

Неправильные настройки безопасности возникают по многим причинам, в том числе:

- Забыли изменить настройки по умолчанию

- Иногда люди просто упускают из виду необходимость изменения настроек по умолчанию при установке новых систем или программного обеспечения. Например, многие устройства и программы поставляются с предустановленными именем пользователя и паролем. Если их не изменить, это все равно, что оставить входную дверь с приветственным ковриком настежь открытой для злоумышленника.
- **Сложность систем**
 - Технические системы могут быть очень сложными. Серверы, базы данных, приложения и всевозможные компоненты, которыми нужно управлять. Это похоже на попытку уследить за большим оркестром, в котором каждый музыкант играет свою роль. Если один музыкант сбивается с ритма, это может испортить все выступление. Точно так же, одна неправильно настроенная конфигурация в системе может привести к значительной уязвимости в безопасности.
- **Незнание определенных функций или настроек, которые могут представлять угрозу безопасности**
 - Иногда люди могут не осознавать, что определенная функция или настройка могут представлять угрозу безопасности. Это подобно тому, как случайно оставить ключи в незапертой машине: вы можете не заметить этого, но ваша машина все равно окажется под угрозой. То же самое может произойти и с технологическими системами, где неосведомленность о рисках может привести к уязвимостям.
- **Устаревшие системы, программное обеспечение или компоненты**
 - Многие продолжают использовать устаревшие системы, программы или компоненты из-за привычки и удобства. Однако, как старый ржавый замок на двери дома не обеспечивает должной безопасности, использование старых технических систем, ПО и компонентов может вызвать серьезные проблемы с безопасностью, ведь часто они не имеют современных функций защиты и более подвержены уязвимостям из-за неправильных настроек.



Помните: понимание причин возникновения этих ошибок — первый шаг к их предотвращению. Как говорится, "человеку свойственно ошибаться". Однако, при тщательном планировании и понимании возможно избежать многих из этих ошибок и обеспечить безопасность наших технических систем.

Как исправить?

- **Изменение настроек по умолчанию**
 - Злоумышленникам часто легко угадать имена пользователей и пароли по умолчанию. Обязательно измените эти значения по умолчанию во время установки и используйте надежные и уникальные учетные данные.



Помимо изменения паролей по умолчанию, также важно правильно их [хранить](#).

- **Минимизация функциональности**
 - Предоставление минимально необходимых прав, доступов, информации об ошибках.
- **Отключение ненужных служб и портов**
 - Заккрытие всех неиспользуемых сетевых портов и отключение ненужных сетевых служб для уменьшения поверхности атаки.
- **Регулярное обновление и исправление систем и компонентов**
 - Постоянное обновление программного обеспечения и операционных систем для устранения известных уязвимостей.
- **Используйте современные протоколы и алгоритмы шифрования**
 - HTTPS, SSH, SFTP вместо HTTP, Telnet и FTP.
 - В качестве хеш-функций вместо MD5 или SHA1, более криптостойкие, например, такие как SHA3 или BLAKE2 и Argon2, bcrypt, scrypt для хеширования паролей.



Об опасности использования устаревших и небезопасных функций можно почитать в [этой](#) статье гайда.